Departamento de Lenguajes y Sistemas Informáticos
E.T.S. Ingeniería Informática. Universidad de Sevilla

Avda Reina Mercedes s/n. 41012 Sevilla
E-mail lsi@lsi.us.es **Web** www.lsi.us.es

E.T.S. ingeniería informática

SEGURIDAD EN SISTEMAS INFORMÁTICOS Y EN INTERNET

CAI 2. CONSULTA SOBRE LA CONFIDENCIALIDAD DE LA INFORMACIÓN EN UNA ENTIDAD HOSPITALARIA (Parte 1)

Un área hospitalaria, que cuenta con múltiples edificios, dispone de un sistema de información que no mantiene cifrados los datos sobre los pacientes que son utilizados por el personal sanitario en toda la entidad, tampoco en el transporte entre los edificios. Por tanto, se incumple claramente el Reglamento General de Protección de Datos (RGPD). La distribución de los soportes que contengan datos de carácter personal se debe realizar cifrando dichos datos u otro mecanismo que garantice que dicha información no sea accesible o manipulada durante su transporte.

El Gerente de la entidad hospitalaria tiene una alta preocupación por la posible fuga de esta información al no estar cifrada, estamos ante un sistema no confiable (untrustworthy). Existe un claro riesgo de fuga de datos que deben ser especialmente protegidos (datos de salud) y que puede producir la pérdida de reputación de la entidad y sanciones que pueden ser de millones de euros por incumplimiento del Reglamento General de Protección de Datos (RGPD), y que pueden imponer las Autoridades de Protección de Datos Personales.

Siendo consciente de los anteriores riesgos, las consultas que nos presenta esta entidad hospitalaria son las siguientes:

a) **Selección de algoritmos de cifrado/descifrado para aplicar a las imágenes**. El Gerente de la entidad hospitalaria nos comunica que desea cifrar todas las radiografías que tiene almacenadas en dicho sistema para su posterior transmisión por las instalaciones hospitalarias a través de soportes y de las redes internas. Nos pide **establecer un ranking de preferencias sobre al menos tres algoritmos diferentes de cifrado** de acuerdo con los criterios especificados abajo por el cliente. Para ello se diseñarán experimentos que podrían servir para construir u**na tabla para el cifrado y otra tabla para el descifrado donde aparezcan** los valores las pruebas realizadas para cada tipo de imagen en cada casilla.

Cifrado/Descifrado Tamaño	Alg1 (ms)	Alg1 (MB)	Alg2 (ms)	Alg2 (MB)	Alg3 (ms)	Alg3 (MB)
Tamaño1 (< 1000KB)						
Tamaño2 (> 1000KB)						

La entidad hospitalaria necesita que dado un fichero se cifre de forma segura y robusta, y que luego se pueda descifrar y volver a recuperar el original. La entidad

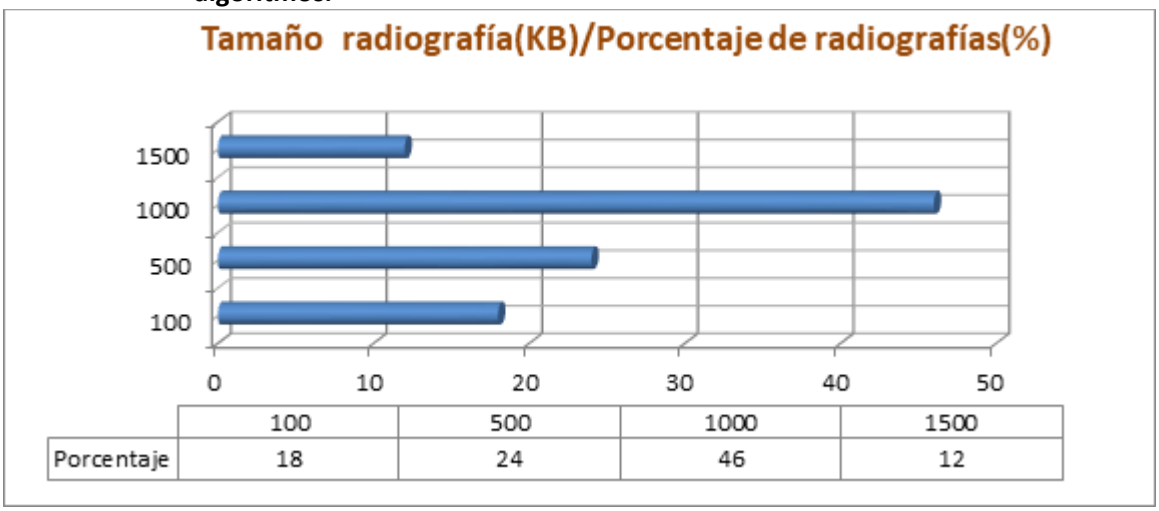
propone utilizar la librería OpenSSL. **Indicar los modos de cifrado de bloque, padding y tamaño de clave que se han considerado más adecuados, y los criterios que se han tenido en cuenta para seleccionar el modo y el tamaño de la clave**. Debe concretar como utilizarla y que parámetros permiten fijar las características anteriores de la forma más segura posible. Por último, debe **explicar el proceso para comprobar la integridad del fichero tras el proceso cifrado/descifrado** de las radiografías que han sido tratadas.

Los técnicos nos comentan que ellos consideran que el algoritmo más adecuado para ello podría ser AES-128-CBC, por su facilidad de uso y eficiencia. Los técnicos informáticos del laboratorio de la entidad hospitalaria nos comunican también que ellos conocen los siguientes algoritmos (pero están abierto a propuestas más útiles y que respondan a los criterios establecidos arriba de la mejor manera posible):

chacha20, salsa20, blowfish, aes-128-cfb, aes-128-ecb, aes-128-ofb, aes-192-cbc, aes-192-cfb, aes-192-ecb, aes-192-ofb, aes-256-cbc, aes-256-cfb, aes-256-ecb, aes-256-ofb, camellia-128-cbc, camellia-128-cfb, camellia-128-ecb, camellia-128-ofb, camellia-192-cbc, camellia-192-cfb, camellia-192-ecb, camellia-192-ofb, camellia-256-cbc, camellia-256-cfb, camellia-256-ecb, cast5-cbc, cast5-cfb, cast5-ecb, cast5-ofb, serpent-128-ecb, serpent-128-cbc, serpent-128-cfb, rsa-2048

Nos indica que los criterios tecnológicos que se deben tener en cuenta en la decisión final son los siguientes por orden de prioridad:

1. **Garantía de que la información cifrada no sea inteligible por terceros.**
2. **Mínima Complejidad temporal (tiempo de ejecución para cifrado/descifrado) y espacial (diferencia entre el tamaño del fichero cifrado y sin cifrar) de los algoritmos.**



La gráfica anterior representa los porcentajes de radiografías (eje X) frente al tamaño aproximado de los ficheros digitales (eje Y) que contienen las radiografías. (1 KB = 1024 bytes)

b) El Gerente de la entidad hospitalaria nos comunica que para **salvaguardar la confidencialidad de la información, algunos usuarios utilizan la herramienta Veracrypt**. Nos consultan como debe hacerse la generación de un contenedor con dicha herramienta para que sea lo más seguro posible. Se deben detallar los algoritmos de cifrado disponibles en cada caso, y una justificación sobre que

algoritmos y opciones se deben utilizar (si la herramienta lo permite) para salvaguardar la confidencialidad de la información almacenada de la forma más segura posible. Debe contener información sobre las pruebas realizadas por los consultores.

También el Gerente nos pide ayuda para la r**ecuperación de la información almacenada en un ordenador.** Se dispone de un contenedor de información generado con la herramienta Veracrypt (en el SO Windows 11). Nos informan que se ha perdido la contraseña usada para el cifrado de dicho volumen, y nos piden ayuda para recuperar dicha contraseña. Sabemos que el contenedor se generó siguiendo todas las opciones por defecto que la herramienta ofrece al usuario para generar/configurar un contenedor cifrado. El cliente recuerda parte de la contraseña, pero no toda. Se sabe que comienza por *abcd..H* y que a continuación debe ir una letra del abecedario y un cero, y por último 3 dígitos numéricos, en total 12 caracteres.

Normas del entregable

- Cada ***Security Team X*** debe entregar el informe ST-X-CAI2A.pdf que contenga todos los detalles que responden a los puntos de la consultoría (se debe indicar expresamente los alumnos del equipo que han participado en el trabajo) a través de la actividad creada al efecto en el curso de Enseñanza Virtual. El informe debe recoger evidencias del proceso, herramientas y pruebas realizadas, así como de las respuestas a las consultas planteadas. Para el apartado a) se deben entregar las imagenes utilizadas para el ejemplo, y el resultado de su cifrado, y los elementos necesarios para su descifrado (todo en el mismo zip que el informe). Para el apartado b) tened en cuenta que la información confidencial debe entregarse en un anexo al final del pdf. Limite de espacio total 8 paginas (incluida portada y anexos).
- La consulta se desarrollará en la sesión dispuesta al efecto, y en el tiempo indicado por el profesor.